PoV Mutual Success Plan:
CSAA / CodeRabbit

INTRODUCTION

This PoV Mutual Success Plan (MSP) is a working draft for CodeRabbit and CSAA's Digital Payment Transformation (DPT) evaluation. It is based on DPT's v2.5 framework/runbook and the October 21, 2026 CodeRabbit assessment. The plan records proposed execution and success criteria; dates and commercial commitments require joint confirmation. No gates or probes have been executed in the supplied evidence package. The DPT core and its decision rules remain authoritative.

THE PROBLEM

CSAA needs to establish whether AI-assisted review adds reliable, actionable signal on its own Bitbucket Cloud platforms: TPS (greenfield Python/AWS serverless), Payment Central (legacy Java/on-premise), and Informatica ETL (on-premise). Review must detect material correctness, payment, contract and operability risks, use the required context, distinguish introduced defects from existing debt, and avoid hallucinations, noise and harmful recommendations. Current reviewer effort, defect/rework levels and expected savings have not yet been measured.

THE SOLUTION

Evaluate CodeRabbit as an advisory reviewer in normal Bitbucket Cloud PRs and a local pre-PR/agent workflow. Supply approved repository, specification and enterprise context; freeze effective settings per evaluation repository; and report native-capability and configured-rule rounds separately. Human reviewers retain approval and merge authority. Configuration, path instructions and custom checks are candidate mitigations to test, not evidence of a pass. Preserve Snyk attribution and independently assess the AI reviewer's added signal.

THE VALUE

The target value is fewer material review misses, less senior-reviewer triage/rework, useful code/test/spec actions, and sustained developer trust. Measure against each platform's last three months of PR activity and locked expected findings using independent evidence. Report quality, harmful findings, effort and adoption per platform; do not average them into

a composite or compare platform scores. ROI, productivity gains, rollout and purchase are not yet established. Outcomes are: Ready to pilot now; Fix named blockers, then pilot; Limited use only; or Do not proceed.

TIMELINE AND KEY ACTIVITIES

- PoV Start Date: TBD — per-platform tool enablement after vendor-risk clearance and locked probe-wave readiness.
- PoV End Date: TBD — three weeks after each platform is enabled; record any approved extension or earlier stop.
- Proposed Contract Start Date: TBD — subject to separate commercial approval; no purchase commitment in this plan.

Pre-PoV	Week 1	Week 2	Week 3	Post-PoV
Phase 0: scope & readiness	Gates, native probes & checkpoint	Domain & configured-rule evaluation	Adoption evidence & decision review	Close blockers; agree pilot/commercials
Activities	**Activities**	**Activities**	**Activities**	**Activities**
☐ Name source repositories and leads; prepare one sanitized <source-repo> -aicr Bitbucket repository per source repo. ☐ Capture the three-month PR/reviewer-load baseline and historical/reviewer-catch inventory. ☐ Lock probe waves, answer keys and	☐ Day 0–2: execute G1–G8; preserve advisory operation and human approval/merge. ☐ Week 1: run applicable P1–P13 against locked keys in the native-capability round. ☐ Exercise A4/E2 with the defined approved	☐ Weeks 1–2: run applicable payment, contract/API, agentic, AWS and PC/IN platform cases. ☐ Run R1–R6 separately against a locked rule profile; budget about one configuration person-day per platform. ☐ Weeks 2–3: start the approved adoption cohort; classify findings and review high-risk accepted advice. ☐ Use office hours to resolve setup issues; log changes and	☐ Continue the defined adoption/trust window; record PR count/size, reviewer load, acted-on rate, near misses and confounds. ☐ End Week 3: DPT compiles platform evidence, Enterprise Architecture reviews, and ARC receives outcomes with NA/untested work, blockers and effort explicit. Extend only for named missing evidence.	☐ Re-run named fixes on the same locked assets under a new manifest; preserve original results. ☐ Agree pilot scope and owners only after the applicable entry rules are met. ☐ Review commercial terms and any contract separately; confirm launch, retention and evaluation-repository cleanup responsibilities.

Pre-PoV	Week 1	Week 2	Week 3	Post-PoV
Phase 0: scope & readiness	Gates, native probes & checkpoint	Domain & configured-rule evaluation	Adoption evidence & decision review	Close blockers; agree pilot/commercials
Activities	**Activities**	**Activities**	**Activities**	**Activities**
non-author scorers; confirm staffing before enablement. ☐ Complete vendor-risk/scopes/data-handling records and freeze context/configuration manifests. ☐ Resolve disposable-only versus live-PR policy and NA versus not-tested handling before execution.	context; preserve raw findings and machine-readable output. ☐ Train participants on evidence capture, comment classification and the human-control boundary. ☐ Amit Mishra chairs the Week 1 continue / constrain / pause / stop decision per platform.	preserve native, configured and remediation results separately.		

SUCCESS INDICATORS:

Required Capability	Description	Priority	Verified	CodeRabbit Comments	CSAA Comments
Workflow, security & human control (G1–G6)	Demonstrate normal Bitbucket Cloud PR operation, advisory/non-blocking review, access beyond the diff, least privilege, and written data-handling clarity. Prevent auto-approval, auto-merge, branch-protection bypass and code pushes without explicit human action. A required gate failure stops or escalates the platform evaluation.	High	Not yet evaluated	Bitbucket and advisory controls are documented. Validate effective settings, credential scopes and denied actions; natural-language instructions are not access controls. Written vendor-risk answers remain required.	For confirmation: Security/vendor-risk lead, approved scopes and data inventory. The runbook records POC SaaS-egress risk acceptance; G5/G6 must still be executed and recorded.
Context, evidence & pre-PR fit (G7–G8, P2–P3, P10, A4/E2)	Prove use of unchanged repository files, the correct frozen spec/acceptance criteria and approved external context; demonstrate local pre-PR or agent-usable output and reliable findings export. Retrieve required linked context without presenting missing required access as true non-applicability.	High	Not yet evaluated	CLI structured output, path guidance and linked-source configuration are candidate routes. Validate actual Bitbucket findings/export fields, spec retrieval and plan/provider limits; changed-line anchoring alone does not prove diff-only reasoning.	For confirmation: code/spec repository scope, approved Jira/Confluence/other sources, frozen revisions and export route. E2 is NA only where the change has no linked ticket; required retrieval failures need a recorded result.
Review correctness & trust (P1, P5–P9, P11–P13)	Score 0–3 against locked keys: historical/seeded replay; no hallucinated APIs/dependencies; correct introduced/pre-existing/touche	High	Not yet evaluated	Run completed full/fresh comparisons on frozen assets/settings. Initial Green	DPT supplies realistic plants/decoys, locked keys and independent scorers. Nobody scores a case they

Required Capability	Description	Priority	Verified	CodeRabbit Comments	CSAA Comments
	d/uncertain origin; honest uncertainty; low noise; repeatability; change-risk test adequacy; concurrency/atomicity; and failure/retry/DLQ handling. Require P5/P6/P7 Green for Ready to pilot now.			calibration includes P1 useful signal ≥40% where comparable, P9 overlap ≥80%, and silence or at most two low-impact comments on a noise control. No claimed detection rates yet.	wrote; apply cross-platform second-scoring rules. TPS is not production-live, so do not invent historical production incidents.
Domain & platform risk coverage (D, C, A, S, PC/IN)	TPS: applicable D1–D9, C1–C8, A1–A5 and core S1/S5/S8/S10. Payment Central: legacy Java/transaction/integration risks. Informatica: readable mappings/workflows and ETL/feed/restart semantics. Apply domain rules only where relevant; A4 remains core. Report each platform independently.	High	Not yet evaluated	General review and approved context may support these cases; detection must be demonstrated. Preserve Snyk findings on the same commits and credit added AI signal under §6.1. Binary/unreviewable Informatica artifacts are not fixed by prompting.	Platform leads define the scoped cases. Confirm payment/contract/AWS applicability; select optional S probes before freezing. Confirm Informatica artifact readability and actual Bitbucket PR workflow before asserting reviewability.
Organizational-rule conformance (R1–R6)	Separately test delivery pipeline conformity, environment configuration completeness, shared component reuse, observability, API security/boundary rules and configuration externalization against a locked, tool-independent platform profile. Do not blend	High	Not yet evaluated	Translate approved general rules into supported path instructions/code guidelines, structural rules or warning-mode custom checks as appropriate. These influence behavior;	Each platform supplies and locks its profile, applicability, positive cases and decoys. Until a profile is locked the R-set is NA; once a rule is applicable, inability to accept/apply it is a failed configured-rule

Required Capability	Description	Priority	Verified	CodeRabbit Comments	CSAA Comments
	this rating into native capability.			they do not guarantee a finding or run the application test suite. Record configuration effort and residual gaps.	result. Track remediation separately.
Adoption, developer trust & business value	During the approved Weeks 2–3 cohort, independently measure actionability, false positives, harmful findings, acted-on rate, reviewer load and end-of-window trust. Initial Green bands: actionable ≥60%, false-positive <20%, no harmful finding observed. Usage, comment count, speed and cost are context, not quality scores.	High	Not yet evaluated	Use raw findings and evaluator classifications as primary evidence; dashboards are supporting evidence. Record numerator/denominator, duplicates, not-assessable findings, PR size, throttling and extra configuration effort. No measured savings or adoption targets are available yet.	Resolve live-use authorization first; define cohort/participants and hold the retrospective. Give accepted high-risk advice a second human look. Record not measured if absent. An acted-on harmful finding on payment/contract/security/irreversible-action paths triggers Do not proceed.

DEPLOYMENT INFORMATION

# of Developers	TBD — CSAA to confirm pilot participants and eligible developer count; capture actual users separately from population.
Developer Teams	DPT: TPS; Payment Central; Informatica ETL. Repository and participant counts to be agreed per platform.

# of Developers	TBD — CSAA to confirm pilot participants and eligible developer count; capture actual users separately from population.
CodeRabbit Deployment	Proposed: hosted CodeRabbit for Bitbucket Cloud plus a local CLI/agent workflow. Vendor-risk, plan/entitlements, installation and G1–G8 validation remain pending.
Git Deployment	Bitbucket Cloud for all three source platforms; sanitized <source-repo>-aicr evaluation repositories. coderabbit-demo/mmani-csaa is tracking only, with reviews disabled.
Network Connectivity	TBD — confirm approved SaaS/Bitbucket/CLI/context egress, proxy/firewall rules and scoped service-account access with Security. No production credentials in evaluation copies.
Cloud Provider	TPS: AWS serverless, RDS and Glue. Payment Central and Informatica ETL: on-premise runtime; do not assume AWS-specific probes apply.
Integrations	Bitbucket Cloud; existing Snyk on TPS; approved specification repositories and Jira/Confluence context. SharePoint/other enterprise-source routes and Snyk availability on PC/IN require confirmation.
Languages	Python, TypeScript, Java and infrastructure-as-code. Informatica mappings/workflows, SQL or scripts only where readable, versioned and in the scoped PR process.
Current PR Reviewer	Human platform reviewers; names, reviewer-catch profile, load and PR-flow baseline captured in Phase 0. CodeRabbit remains advisory and retains no approval/merge authority.
Issue Tracking	Jira and Confluence are required-context candidates in the framework; confirm projects, linked-ticket conventions, access and evidence retention. Track this evaluation in mmani-csaa.
IDE	TBD — platform teams to confirm supported IDEs, extension needs and managed installation. Demonstrate G8 through an approved pre-PR route.
Coding Agent	TBD — confirm actual agent(s) and local workflow. TPS includes agentic probes; human approval of proposed repairs remains required.

CSAA TEAM

Role	Name	Title	Email
Project Lead	Amit Mishra	DPT core/probe/evidence owner and Week 1 decision owner (runbook role; formal title TBD)	TBD — confirm
Technical Lead	TPS: Sasi, Kasa, Sadak; Payment Central: Karthikeyan Subbiah; Informatica ETL: Ashin	Platform evaluation leads (formal titles and primary contact TBD)	TBD — confirm
Security Lead	TBD — named Security/vendor-risk contact	Security and data-handling review; G5/G6 evidence	TBD — confirm
Executive Sponsor	TBD — evaluation sponsor	Funding/escalation owner; ARC is the final decision forum, not a named individual sponsor	TBD — confirm

CODERABBIT TEAM

Role	Name	Title	Email
Account Manager	TBD — confirm account owner	TBD — confirm	TBD — confirm
Technical Lead	TBD — confirm technical PoV owner	TBD — confirm	TBD — confirm
Executive Sponsor	TBD — confirm executive sponsor	TBD — confirm	TBD — confirm